

Système de pointage biométrique — plan de développement

How we build the GTA software that the CCTP describes: the architecture forced by the tender's own constraints, the domain model, the rules engine that is the real work, and a 60-day delivery broken into nine phases with honest effort numbers.

TERMINALS 25	BLOCS 25	SERVICES 35+	AGENTS 3 000+
DÉLAI CONTRACTUEL 60 jours		EFFORT ESTIMÉ ~130 j.dev	

01 Constraints → decisions	02 Build vs buy	03 Stack
04 Open source & licences	05 Architecture	06 Device layer
07 Data model	08 Rules engine	09 API surface
10 Repo layout	11 Phases P0–P8	12 Scope tiering
13 Effort & team	14 Risk register	

01 Constraints → decisions

The CCTP prescribes an operating environment. Every architectural choice below is traced back to the clause that forces it, so the offer stays defensible line by line during technical analysis.

CCTP CLAUSE	DECISION	WHY THIS AND NOT THE ALTERNATIVE
Serveur Windows, dernière version originale	Windows Server + Node.js runs as a Windows Service (NSSM), IIS as reverse proxy on 443	The hospital's IT unit already operates Windows and IIS. Running Node behind IIS keeps certificate management, logging and restart policy inside tooling they know.
SQL Server 2019+ ou MySQL 5.7+	MySQL 8.0 via Prisma	Satisfies "MySQL 5.7 ou supérieur" literally, is free of licence cost for the client, and Prisma's MySQL provider is production-grade. PostgreSQL — our usual default — is <i>not</i> an allowed engine here and would be a conformity gap.
.NET Framework 4.8 ou supérieur	A .NET 4.8 Windows Service hosting the terminal SDK bridge	The clause exists because vendor biometric SDKs are COM/.NET on Windows. Instead of treating it as a box to tick, we use it for exactly what it is good at: enrollment and template sync.
JRE si requis par des modules spécifiques	Not required by our design; documented as "non applicable"	No Java component in the stack. Stated explicitly so the evaluator does not read it as an omission.
Portail internet ou intranet, navigateurs Chrome / Firefox / Edge	Server-rendered shell + React SPA, no client install	"Aucune installation sur les postes" is a selling point against desktop-client competitors and removes 3 000 endpoints from the deployment plan.
Compatibilité multi-marques (ZKTeco, Suprema, Hikvision)	Driver interface with one adapter per vendor	Single point of variation. A new brand is a new adapter, not a fork of the application.
Loi organique n° 63/2004	Templates only, never raw biometrics; local hosting; full audit trail	Storing a face image would be both a legal exposure and a technical liability. Vendor templates are non-reversible by construction.
Support multilingue + accessibilité	i18next with FR / AR (RTL) / EN, logical CSS properties throughout	RTL retrofitted late is a rewrite. Using <code>margin-inline-start</code> rather than <code>margin-left</code> from commit one costs nothing now.
Environnement de test à disposition	Second instance (staging) on the same server, separate DB and port	Contractually required. Also our UAT and training sandbox, so it earns its keep three times.

02 Build vs buy

Four ways to obtain the application layer. Two of them are eliminated by the CCTP itself, not by preference — which is the only argument that survives technical analysis.

OPTION	WHAT IT IS	WHAT DECIDES IT	VERDICT
A — Vendor suite ZKBio Time · HikCentral	Resell the terminal manufacturer's own time-and-attendance software. Environment-compliant on paper: Windows Server, MySQL 8 or MS SQL, REST API, mobile apps, up to 500 devices.	"Compatibilité multi-marques" names ZKTeco, Suprema and Hikvision; each vendor suite drives only its own brand. Art. 9 — "maintenance évolutive : développement et déploiement de nouvelles fonctionnalités" commits us to develop for five years. On closed third-party software that obligation cannot be honoured.	REJECTED

OPTION	WHAT IT IS	WHAT DECIDES IT	VERDICT
B — Fork an open HRMS Frappe HR · Horilla · Odoo · TimeTrex	Take an existing open-source HR suite and customise its attendance module.	"Serveur Windows" and "SQL Server 2019+ ou MySQL 5.7+": Odoo requires PostgreSQL and Horilla defaults to it — neither is a permitted engine. Frappe HR requires MariaDB and is Linux-first (Windows only through Docker/WSL). Copyleft compounds it: GPL and AGPL make delivery to the CHU a distribution that obliges source disclosure, which contradicts the perpetual-licence article and contaminates reuse on other tenders.	REJECTED
C — Everything from scratch	Write every layer ourselves, including the terminal protocol.	No clause forbids it, but the ZK TCP/IP protocol already has mature permissive implementations. Reimplementing it spends roughly ten days on the riskiest part of the project for no conformity gain.	WASTEFUL
D — Own the domain, assemble the rest	Build the business layer ourselves on permissively licensed open-source components, with collection over the open ZK protocol and ADMS push.	Satisfies multi-brand by construction, makes five years of maintenance évolutive actually deliverable, keeps the product ours, and fits the mandated Windows + MySQL environment.	ADOPTED

What "adopted" means in practice

- Roughly **65 of the 130 dev-days are bespoke domain logic** — rules engine, planning, absences, reports. The rest is integration, assembly, deployment and documentation.
- No third-party attendance product is resold, and no HRMS is forked. The only vendor-specific code is the driver adapters, isolated behind one interface.
- The delivered product contains permissively licensed components only — see §04.

SCOPE DISCIPLINE

Every T1 feature in this plan traces to a named article of the CCTP. Anything that does not trace is **out of scope** — it is logged for maintenance évolutive and discussed with the DRH, not built quietly. Two consequences already applied: no two-factor authentication (the security clause asks for password storage, complexity and renewal, nothing more), and no cross-site travel-time anomaly detection (not requested). Gold-plating a fixed-price public contract is how margin disappears.

03 Stack

LAYER	CHOICE	NOTES
Language	TypeScript 5.x, strict	Shared types between API, web and mobile via a <code>packages/contracts</code> workspace.
Runtime	Node.js 20 LTS	Runs as a Windows Service. LTS window covers the 5-year maintenance commitment.
HTTP	Fastify 4	Schema-first validation with typebox, which doubles as the OpenAPI source for the CCTP-mandated REST API.
ORM	Prisma 5 → MySQL 8	Migrations under version control — needed for the "plan de test" and rollback story.

LAYER	CHOICE	NOTES
Jobs	DB-backed queue (jobs table + worker)	Deliberately <i>not</i> Redis. One less service to install, monitor and explain on a hospital Windows box.
Realtime	socket.io	Live presence board and device-status ticker.
Web	React 18 + Vite + Tailwind + shadcn/ui	TanStack Query for server state, TanStack Table for the dense grids, dnd-kit for the planning board.
Mobile	React Native + Expo	Geolocation, geofencing, offline queue via SQLite.
Terminal protocol	zklib-js / node-zklib (MIT)	Open Node implementation of the ZK TCP/IP protocol — logs, users, clock, device info. The same protocol layer Frappe HR and Horilla reach through <code>pyzk</code> .
Device bridge	.NET 4.8 Windows Service (<i>reduced</i>)	Retained only for biometric template read/write where the vendor SDK is the sole supported path. .NET 4.8 stays installed either way — the CCTP lists it as an environment prerequisite.
Auth	JWT access + refresh, argon2id	Password complexity, renewal policy and lockout as the security clause requires — and nothing beyond it.
Reports	ExcelJS · pdfmake · csv-stringify	Covers the Excel / PDF / CSV export triad named in the CCTP.
Tests	Vitest · Supertest · Playwright	The rules engine gets property-based tests; that is where correctness money is spent.
Ops	IIS + ARR · NSSM · mysqldump + Task Scheduler	Every piece is something the hospital IT unit can already operate.

04 Open source & licences

Everything below the domain layer is open source. That is the point — but the licences are chosen, not inherited.

THE RULE

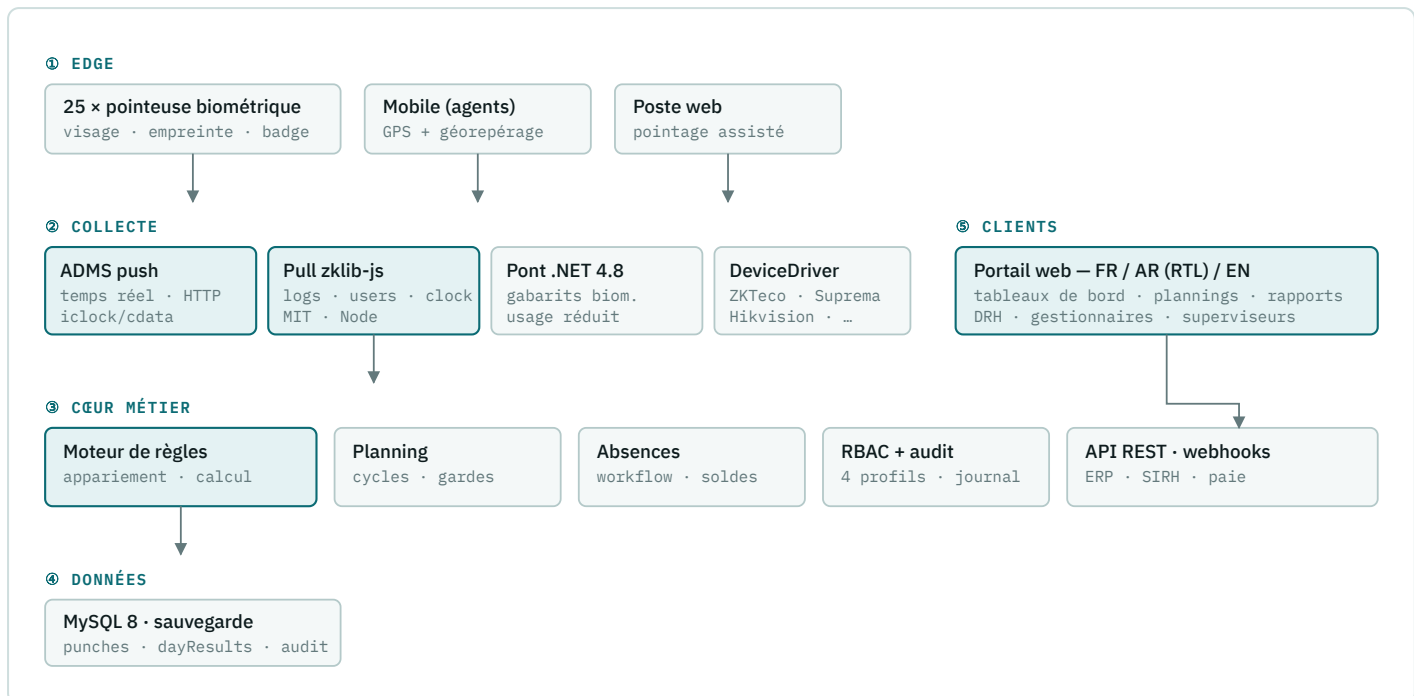
Only **permissive** licences ship inside the product: MIT, Apache-2.0, BSD, ISC. **No GPL, AGPL or LGPL-linked component** is included in what is delivered to the CHU. Two reasons: copyleft would oblige us to disclose source on delivery, which is neither what the CCTP asks for nor consistent with the perpetual-licence commitment in the offer; and it would contaminate reuse of the same product on other tenders.

COMPONENT	ROLE	LICENCE
zklib-js · node-zklib	ZK protocol over TCP/IP — logs, users, clock	MIT
Fastify	HTTP server, schema validation, OpenAPI generation	MIT
Prisma	ORM and versioned migrations against MySQL 8	Apache-2.0
React · Vite	Portal front end	MIT
Tailwind CSS · shadcn/ui	Design system, logical properties for RTL	MIT
dnd-kit	Planning board drag-and-drop	MIT
TanStack Query · Table	Server state and dense data grids	MIT
i18next	FR / AR (RTL) / EN	MIT
ExcelJS · pdfmake · csv-stringify	Excel, PDF and CSV exports	MIT
React Native · Expo	Mobile punch module	MIT
argon2 · jose	Password hashing, token signing	Apache-2.0 / MIT
Vitest · Supertest · Playwright	Test tooling (not shipped)	MIT

A software bill of materials — every component with its version and licence — is generated at build time and delivered as part of the **"rapports de conformité"** the CCTP requires. It costs one CI step and answers a question the evaluator would otherwise have to ask.

05 Architecture

Five tiers. The important line is between the vendor-specific edge and everything above it: only the adapters know what a ZKTeco is. Tier ② now has three independent capture paths, so no single dependency can stop attendance from being recorded.



Punches reach tier ③ by push or by scheduled pull, both in Node. The .NET bridge sits only on the biometric-template path, so it can fail — or be dropped entirely after the P0 field test — without affecting attendance capture.

06 Device layer

The single most common way these projects fail is treating terminals as a solved problem. Two transport modes, chosen per capability, not per preference.

Mode A — ADMS push (primary)

ZKTeco terminals with the push firmware POST attendance records over plain HTTP to a server URL configured on the device. No SDK, no polling, no COM interop, and no Windows dependency on the receiving side. This is the path for all 25 terminals in normal operation.

- The device opens the connection outbound — no inbound firewall rule per terminal, which the hospital network team will appreciate.
- Records arrive within seconds; the terminal retries on its own if the server is down.
- We answer with an ack and a command queue, which is also how we push user lists and door commands back down.

Mode B — Scheduled pull over the open ZK protocol (reconciliation)

The ZK TCP/IP protocol has mature permissive Node implementations — `zklib-js`, `node-zklib` — the same protocol layer that Frappe HR and Horilla reach through `pyzk`. A nightly reconciliation pull re-reads each terminal's log window and fills any gap the push path missed, and the same library provisions users, sets the clock and reads device info.

This is the change from the first version of this plan: what was scoped as a .NET SDK job is Node work using an existing MIT library. It removes roughly five dev-days from the riskiest workstream and keeps the whole collection path in one language.

Mode C — .NET 4.8 bridge (biometric templates only)

A .NET 4.8 Windows Service hosting the vendor SDK is retained for one job: reading and writing face and fingerprint templates on firmwares where the official SDK is the only supported path. It is not on the attendance path at all.

The P0 field test against a physical terminal decides its fate. If templates prove reachable through the open protocol, the bridge is dropped and .NET 4.8 remains simply as the environment prerequisite the CCTP lists — which we install regardless.

Driver interface

All three modes land on one interface. Adding Suprema or Hikvision later means implementing this contract, nothing else — which is how the multi-marques clause is satisfied structurally rather than by promise.

```
interface DeviceDriver {
  probe(): Promise<DeviceInfo>;           // serial, firmware, capacities
  pullEvents(since: Date): Promise<RawPunch[]>;
  pushUsers(users: DeviceUser[]): Promise<SyncReport>;
  readTemplate(userId, kind): Promise<Template>;
  writeTemplate(userId, t: Template): Promise<void>;
  syncTime(): Promise<void>;
  health(): Promise<DeviceHealth>;       // online, storage, tamper
}
```

DESIGN RULE

A raw punch is written to `punches` exactly as the terminal reported it and is **never mutated**. Every correction is a new row with a link to the original and the name of whoever made it. This is what makes the audit trail defensible in a payroll dispute — and it is cheap to build on day one, expensive to retrofit.

Device monitoring

A worker pings all 25 terminals every 60 seconds and records last-seen, storage headroom and tamper state. A terminal silent for more than five minutes raises an alert in the app and by email to the unité informatique. This is a small feature that carries most of the perceived reliability of the whole system.

07 Data model

Twenty-two tables. The one that decides whether monthly reporting takes 40 seconds or 40 minutes is `day_result`.

GROUP	TABLES	PURPOSE
Organisation	site · service · employee · employee_category	25 blocs, 35+ services, 3 000+ agents. Category drives which rule set applies (médical, paramédical, administratif, ouvrier).
Terminals	device · device_enrollment · credential · device_command	Which agent is enrolled on which terminal, with what credential. <code>device_command</code> is the outbound queue consumed by the push ack.
Raw capture	punch · punch_correction	Append-only. <code>punch</code> carries source (TERMINAL / WEB / MOBILE), verify mode, and lat-lng when mobile.

GROUP	TABLES	PURPOSE
Planning	shift_template · cycle · cycle_step · schedule_entry	Fixed, variable and cyclic patterns. shift_template carries crossesMidnight, grace tolerances and break rules.
Absences	absence_type · absence_request · absence_day · leave_balance	absence_day is the exploded per-day form — it is what the rules engine joins against, not the request range.
Computed	day_result · overtime_request · anomaly	One row per agent per day: theoretical minutes, worked minutes, late, early leave, overtime, absence overlay, anomaly flags.
Access	user · role · permission · user_scope	user_scope is what makes RBAC real: a Gestionnaire is scoped to services, a Superviseur to one team.
Platform	audit_log · notification · setting · job · webhook_subscription	Audit is written by a Prisma middleware, so no route can forget it.

WHY DAY_RESULT EXISTS

3 000 agents × 30 days is 90 000 rows a month, each requiring punch pairing, planning lookup and absence overlay. Computing that on demand for a monthly export is the difference between a report that returns and one that times out. day_result is recalculated incrementally whenever a punch, a planning entry or an absence touching that date changes — and can be fully rebuilt for any period from raw data, which is also the recovery story.

08 Rules engine

This is the project. Everything else is CRUD around it. A hospital has 24-hour gardes, 3×8 roulements, astreintes and part-time medical staff, and the CCTP asks for "horaires fixes et variables" as if that were one checkbox.

Pipeline

- Normalise** — deduplicate punches within a configurable window (an agent badging twice in 30 seconds is one event, not two).
- Resolve the working day** — assign each punch to a *business day*, which for a night shift is not the calendar day of the timestamp.
- Pair** — build IN/OUT sessions. When a punch is missing, flag rather than guess: an unpaired punch becomes an anomaly the supervisor resolves, never an invented time.
- Match to plan** — find the schedule_entry for that agent and business day, expanding from the cycle when no explicit entry exists.
- Compute** — worked minutes, late minutes past tolerance, early departure, break deductions, overtime above the planned envelope.
- Overlay absences** — an approved absence covering the day replaces the expectation rather than producing an absence anomaly.
- Flag** — missing punch, punch with no plan, impossible transition (two blocs within minutes), overtime pending validation.
- Persist** — upsert day_result, emit notifications and webhooks.

Cases that must have tests before anything else is written

CASE	EXPECTED BEHAVIOUR
Garde de 24 h, in 08:00 J1 → out 08:15 J2	One session on business day J1, 24 h worked, 15 min overtime. J2 shows no absence.
Poste de nuit 20:00 → 06:00	Business day = start date. Both punches attach to J1 even though the exit is on J2.

CASE	EXPECTED BEHAVIOUR
Roulement 3×8, semaine de bascule	Cycle expansion produces the right template per day, including the transition week.
Missing exit punch	Anomaly <code>MISSING_OUT</code> , worked minutes null, day excluded from payroll export until resolved.
Approved congé annuel over a planned shift	Theoretical minutes preserved, worked = 0, no late/absence anomaly, counted against balance.
Punch on a bloc the agent is not assigned to	Accepted and recorded, flagged <code>OFF_SITE</code> for supervisor review — never rejected silently.
Retroactive planning change on a closed month	Recompute is refused on a locked period; requires an explicit unlock recorded in the audit log.
Duplicate push delivery from a terminal after retry	Idempotent on (device, deviceId, timestamp) — no double punch.

DO THIS IN WEEK ONE

Run a two-hour workshop with the DRH and the surveillant général to write down the real rules: tolerance in minutes, how gardes are paid, what counts as an astreinte, whether break time is deducted, and how the month is closed. Every day this is delayed is a day the rules engine is being built against assumptions. This workshop is the highest-leverage two hours in the whole project.

09 API surface

The CCTP requires a documented REST API, native connectors and webhooks. Fastify schemas generate the OpenAPI document, which becomes an offer annex at no extra cost.

```
# Capture
POST /iclock/cdata          ADMS push ingress (device-facing)
POST /api/v1/punches        web / mobile punch
GET  /api/v1/punches?from&to&service

# Planning
GET  /api/v1/schedules?service&week
PUT  /api/v1/schedules/:id
POST /api/v1/cycles/:id/apply    expand a rotation over a period

# Absences
POST /api/v1/absences          agent submits
POST /api/v1/absences/:id/decision approve | reject + motif
GET  /api/v1/balances/:employeeId

# Results & reports
GET  /api/v1/day-results?employee&from&to
POST /api/v1/reports/monthly    → job id
GET  /api/v1/reports/:jobId/export?format=xlsx|pdf|csv

# Devices
GET  /api/v1/devices            status, last seen, storage
POST /api/v1/devices/:id/sync-users

# Integration
POST /api/v1/webhooks            subscribe: punch.created,
                                absence.approved, device.offline
GET  /api/v1/exports/payroll?period SIRH / paie connector
```

10 Repo layout

One pnpm workspace, new repository, no dependency on the Hikview ERP codebase.

```
pointage-rabta/
├── apps/
│   ├── api/                Fastify + Prisma – core services
│   │   ├── src/modules/{attendance,planning,absence,report,device,auth,audit}
│   │   ├── src/engine/     rules engine – pure functions, heavily tested
│   │   └── prisma/schema.prisma
│   ├── web/                React + Vite portal
│   ├── mobile/             Expo app
│   └── bridge/              .NET 4.8 Service – biometric templates only, if P0 requires it
├── packages/
│   ├── contracts/          shared zod schemas + TS types
│   ├── drivers/            DeviceDriver implementations per brand
│   └── i18n/               fr · ar · en resource bundles
├── ops/
│   ├── iis/                reverse proxy + rewrite rules
│   ├── backup/             mysqldump + retention + restore scripts
│   └── install/            NSSM service registration, first-run checklist
└── docs/                   livrables CCTP: exploitation, pannes, messages d'erreur
```

`docs/` is part of the repo, not an afterthought: the CCTP requires the exploitation manual, the probable-failures guide and the error-message guide in three copies each. Writing them alongside the code is how they end up accurate.

11 Phases P0 – P8

Day numbers are counted from the ordre de service (J0), except P0 which runs before award. Phases overlap deliberately — the device layer and the rules engine are worked in parallel by different people.

P0

pre-award

De-risk and pre-build

The 60-day clock is not enough for a cold start. This phase costs little and removes the two things that historically blow the schedule.

- ZKTeco ADMS push spike against one physical terminal — prove the ingress path end to end.
- **Template spike with `zklib-js`** — establishes whether the .NET bridge is needed at all, or can be dropped from scope.
- Rules workshop with the DRH; write the rule set down.
- Prisma schema, repo scaffold, CI, auth and RBAC skeleton, i18n shell.
- UX prototype validated with the DRH (dashboard + planning board).

EXIT — a punch from a real terminal lands in a real database, and the rule set is written down and signed off.

P1

J0 – J10

Foundation

- Full data model migrated; seed with the 25 blocs and 35+ services.
- Auth, refresh tokens, argon2id, TOTP for admins.
- RBAC with the four CCTP profiles and `user_scope` enforcement in a single guard.
- Audit middleware, settings module, job runner.
- Employee import from the existing HR file (matricule, service, catégorie).

EXIT — an Administrateur can log in, import 3 000 agents, and every action is in the audit log.

P2

J8 – J20

Device layer

- ADMS ingress with idempotency and command queue.
- Scheduled reconciliation pull on `zklib-js`: probe, user provisioning, clock sync, log backfill.
- .NET 4.8 bridge for biometric templates — built only if the P0 spike showed it is required.
- ZKTeco adapter behind `DeviceDriver`; Suprema and Hikvision adapters stubbed to the same contract.
- Device console: status, last seen, storage, tamper, offline alerting.
- **Enrollment tooling** — a station mode for bulk biometric capture by service.

EXIT — 25 terminals reachable, agents enrollable in batches, punches flowing live.

P3

J15 – J30

Rules engine & planning

- Pipeline implemented as pure functions with the eight test cases above green first.
- Shift templates, cycles, cycle expansion, night-shift business-day resolution.
- Planning board: weekly and monthly, drag-and-drop, team view, bulk apply a cycle.
- Incremental `day_result` recomputation + full rebuild command.

EXIT — a month of real punches produces day results the DRH agrees with, sampled against manual calculation.

P4

J25 – J38

Absences, overtime, notifications

- Absence types, request → decision workflow, day explosion, balances.
- Overtime detection and validation by the Gestionnaire.
- Notification centre: missed punch, pending approval, planning change, device offline. In-app + email.
- Anomaly queue with supervisor resolution and full traceability of corrections.

EXIT — an agent requests leave on mobile-web, the head of service approves, and the day result changes accordingly.

P5

J30 – J42

Dashboards & reports

- Live presence board by bloc and service; personalisable KPI dashboard.
- Report builder: presence, absence, retards, heures supplémentaires, écarts au planning.
- Exports to Excel, PDF and CSV, generated as background jobs.
- Monthly close: lock a period, produce the payroll extract.

EXIT — the monthly state for 3 000 agents generates in under 60 seconds and matches sampled manual figures.

P6

J35 – J45

Mobile module

- Expo app: punch with geolocation, geofence per site, offline queue.
- Planning, balances, notifications, absence request.
- Anti-fraud: device binding per agent, mock-location detection.

EXIT — a punch taken outside the hospital arrives flagged with its coordinates and geofence verdict.

P7

J40 – J50

Integration & hardening

- Public REST API + OpenAPI document; webhook subscriptions with retry.
- Payroll / SIRH connector in the format agreed with the DRH.
- Backup, retention and a *tested* restore; automated at Task Scheduler level.
- Security pass: dependency audit, rate limiting, headers, session policy, penetration test.
- Load test at 100 concurrent users and 25 terminals pushing simultaneously.

EXIT — restore from backup rehearsed on the staging instance and timed.

P8

J48 – J58

Deployment, UAT, formation

- Production + staging on the hospital server; IIS, certificates, Windows Services.
- UAT with real users on real scenarios; defect triage and fixes.
- Four days of training as committed in the mémoire technique.
- Documentation package: exploitation manual, failure guide, error-message guide, plans de recollement.

EXIT — procès-verbal de réception provisoire signed.

12 Scope tiering

Not everything in the CCTP has to exist on J60. Tiering it explicitly — and saying so to the client — is how the deadline is met without either cutting corners silently or over-promising.

TIER	WHEN	CONTENTS
T1	by réception provisoire	Capture from 25 terminals · organisation & agents · planning (fixe, variable, cyclique) · rules engine · absences workflow · overtime · anomaly queue · dashboards · reports + Excel/PDF/CSV · RBAC 4 profils · audit · notifications in-app & email · backup/restore · FR + AR (RTL) + EN · minimal mobile punch with geolocation · staging environment · SBOM for the rapports de conformité

TIER	WHEN	CONTENTS
T2	during the 12-month garantie	Full mobile app (planning, balances, offline queue, device binding) · webhooks and external API consumers · payroll connector hardening · advanced analytics and custom dashboards · Suprema and Hikvision adapters activated against real hardware
T3	maintenance évolutive, 5 ans	Defined with the DRH and the unité informatique as needs emerge, per Art. 9. Nothing is pre-committed here — listing speculative features in a fixed-price offer creates expectations the contract does not fund.

CONTRACTUAL NOTE

The CCTP names mobile pointage as a requirement, so it cannot sit entirely in T2. T1 therefore ships a working mobile punch with geolocation and geofencing — enough to demonstrate conformity at recette — while the full companion app lands during the warranty period as maintenance évolutive, which the contract explicitly provides for.

The tiering is agreed with the DRH **in writing before UAT begins**. Without that, every T2 item becomes a T1 expectation the moment a user sees the screen it is missing from.

13 Effort & team

WORKSTREAM	DEV-DAYS	NOTES
Foundation, auth, RBAC, i18n (FR/AR/EN), import	11	Mostly known work. EN locale is nearly free once i18n exists.
Device layer (ADMS push, <code>zklib-js</code> pull, reduced bridge, console, enrollment)	10	Was 15. The open ZK library removes the SDK work; the bridge shrinks to templates only.
Rules engine + planning UI	25	Bespoke. The core. Drag-and-drop board is a third of it.
Absences, overtime, notifications, anomalies	15	Bespoke.
Dashboards, reports, exports, monthly close	15	Bespoke. Export formatting always overruns.
Mobile (T1 scope)	10	Full app in T2 adds ~10 more.
API, webhooks, hardening, backup, security, SBOM	12	
Deployment, UAT, load & pen test	10	
Documentation & training material	8	CCTP-mandated, three copies each.
Contingency (12%)	14	Below this, the plan is fiction.
Total	130	Of which ~65 is bespoke domain logic (rows in bold plus the domain share of mobile and API).

THE HONEST ARITHMETIC

60 calendar days is roughly **40 working days**. $130 \text{ dev-days} \div 40 = \mathbf{3.25 \text{ developers}}$ working the full window — and that assumes hardware installation runs in parallel without stealing engineering time, which it will not.

Choosing option D over building everything from scratch bought five days, not thirty. It removes risk rather than headcount: the team size does not change, the riskiest workstream gets smaller.

Two viable configurations: **(a)** run P0 before award so ~25 dev-days are already banked at J0, then two full-time developers plus one part-time can hold the schedule; or **(b)** staff three developers from J0 and accept that the first week is spent on decisions P0 would have already settled. Option (a) is cheaper and safer. Option (c) — one developer, 60 days — does not exist, and planning as if it does is how a réception provisoire gets missed.

Suggested split

- Dev A — backend / engine.** Data model, rules engine, planning logic, reports, monthly close.
- Dev B — frontend.** Portal, planning board, dashboards, i18n and RTL, accessibility.

- **Dev C — device & ops.** ADMS ingress, `zklib-js` pull, adapters, enrollment tooling, deployment, backup, monitoring — plus the .NET bridge only if P0 shows it is needed. Rolls onto mobile at P6.

14 Risk register

RISK	SEV	MITIGATION
Biometric enrollment of 3 000+ agents. At a realistic 45 agents per hour, that is roughly 70 hours of enrollment across 25 blocs, in shift patterns that never put everyone in one place.	HIGH	Enrollment station mode built in P2, not improvised at P8. Schedule by service with the surveillant général, run mobile enrollment kits, start during the cabling phase rather than after it. Badge-first fallback: issue RFID badges immediately, add face and fingerprint progressively.
Rules ambiguity. "Horaires fixes et variables" hides gardes, astreintes, 3×8 and part-time medical contracts.	HIGH	The P0 workshop, with a written and signed rule set. Any rule discovered later is handled as a change request against the ±20% clause, not absorbed silently.
Cold start at J0. No pre-award work means the first two weeks go to decisions rather than code.	HIGH	Run P0 now, at our own cost. It is reusable across the Kairouan municipality tender and any future pointage client, so it is not sunk if this award goes elsewhere.
Hospital network access. VLAN, firewall rules, fixed IPs and server access all depend on a third party's calendar.	MED	Formal request to the service informatique in the first week, with the exact ports and address plan. ADMS push helps: terminals connect outbound, so no per-device inbound rule is needed.
HR data quality. Matricules, service assignments and categories are rarely clean in a 3 000-person establishment.	MED	Import with a validation report at P1, not at UAT. Duplicates and orphan services surface early enough for the DRH to fix them.
Windows operations. Node as a service, IIS reverse proxy, MySQL tuning and scheduled backups on a box we do not own.	MED	Rehearse the entire install on a local Windows Server VM during P1 and script it. The install must be repeatable before it is performed on site.
Terminal spec gap — the USB port question raised in the conformity review.	MED	Confirm against the distributor's Product Data before the offer is filed. Software-side it is immaterial: the collection path is Ethernet.
Biometric templates need the vendor SDK. If the P0 spike shows templates are unreachable through the open protocol, the .NET bridge stays in scope and COM interop on Windows Server becomes a real workstream.	MED	The spike happens in P0, before anything depends on the answer. Worst case restores the original 15-day device estimate — which the contingency already covers. Badge-first enrollment also works without any template handling at all.
Licence contamination. A copyleft component pulled in transitively would oblige source disclosure on delivery and block reuse on the Kairouan tender.	LOW	Automated licence check in CI failing the build on any GPL, AGPL or LGPL-linked dependency. The SBOM is a delivered artefact, so the check has to pass anyway.
Scope creep during UAT. Users discover what they actually wanted once they see it.	LOW	Every feature traces to a CCTP article; tiering is agreed in writing before UAT starts. New requests are logged against T2 maintenance évolutive, which the contract already covers and funds.

Revision 2 — build-vs-buy decision recorded (§02), permissive-licence rule and component inventory added (§04), device layer restructured around the open ZK protocol with the .NET bridge reduced to biometric templates (§06), effort revised from 135 to 130 dev-days, scope trimmed to CCTP-traceable features only.

Plan de développement — logiciel de gestion des temps et de pointage biométrique · CHU La Rabta, consultation N° INF01/2026 · HIKVIEW ENGINEERING. Day numbers are counted from the ordre de service. Effort figures are dev-days for one developer at full capacity, contingency included.